

Lesson 01 Demo 05

Performing Penetration Testing Using OWASP ZAP and GitHub Actions

Objective: To configure and execute penetration testing on a web application using OWASP ZAP integrated with GitHub Actions for identifying vulnerabilities and enhancing application security

Tools required: GitHub Actions and OWASP ZAP

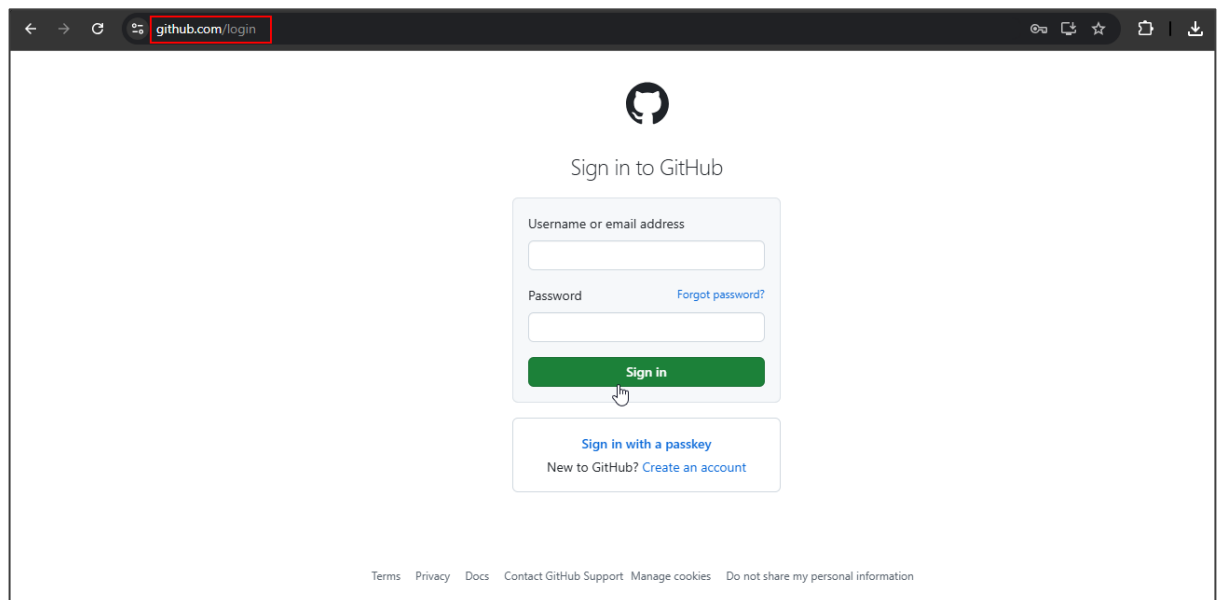
Prerequisites: None

Steps to be followed:

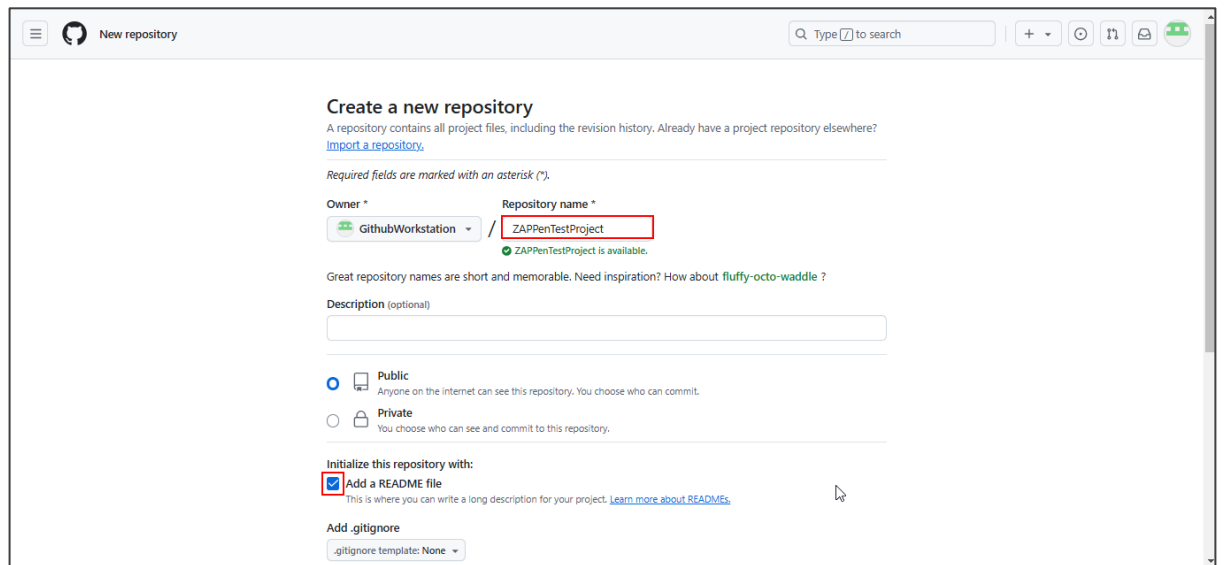
1. Configure the DAST tool with GitHub Actions

Step 1: Configure the DAST tool with GitHub Actions

- 1.1 Sign in to your GitHub account using the following URL:
<https://github.com/login>



1.2 Create a repository, add a desired name, and click on the check box to add a README file



Create a new repository

A repository contains all project files, including the revision history. Already have a project repository elsewhere? [Import a repository.](#)

Required fields are marked with an asterisk ().*

Owner * **Repository name ***

GithubWorkstation / ZAPPenTestProject

✓ ZAPPenTestProject is available.

Great repository names are short and memorable. Need inspiration? How about [fluffy-octo-waddle](#)?

Description (optional)

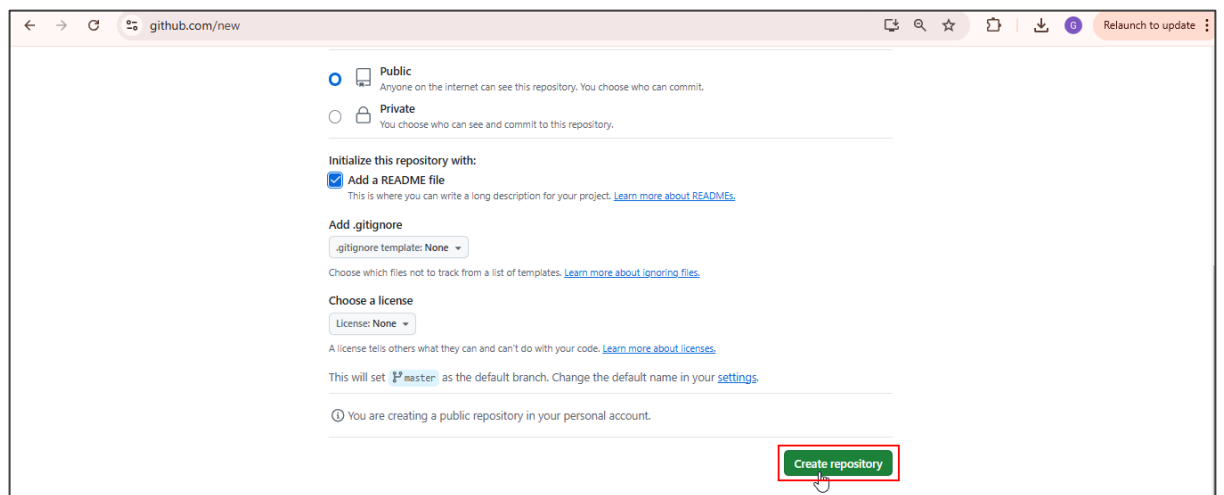
☒ **Public**
Anyone on the internet can see this repository. You choose who can commit.

☐ **Private**
You choose who can see and commit to this repository.

Initialize this repository with:

☒ **Add a README file**
This is where you can write a long description for your project. [Learn more about READMEs.](#)

Add .gitignore
.gitignore template: None



[github.com/new](#)

☒ **Public**
Anyone on the internet can see this repository. You choose who can commit.

☐ **Private**
You choose who can see and commit to this repository.

Initialize this repository with:

☒ **Add a README file**
This is where you can write a long description for your project. [Learn more about READMEs.](#)

Add .gitignore
.gitignore template: None

Choose which files not to track from a list of templates. [Learn more about ignoring files.](#)

Choose a license
License: None

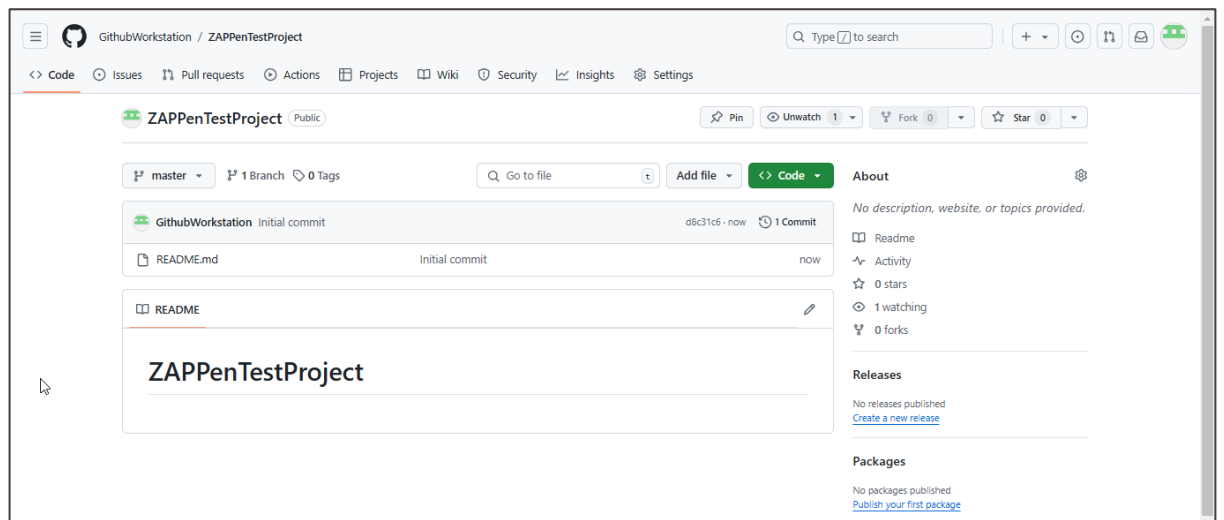
A license tells others what they can and can't do with your code. [Learn more about licenses.](#)

This will set `master` as the default branch. Change the default name in your [settings](#).

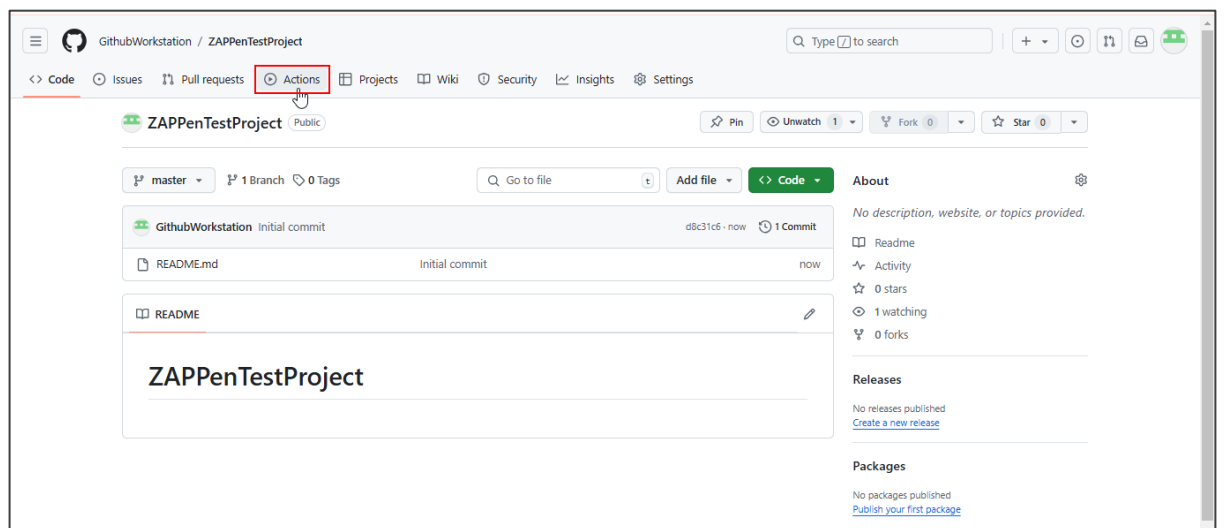
☐ You are creating a public repository in your personal account.

Create repository

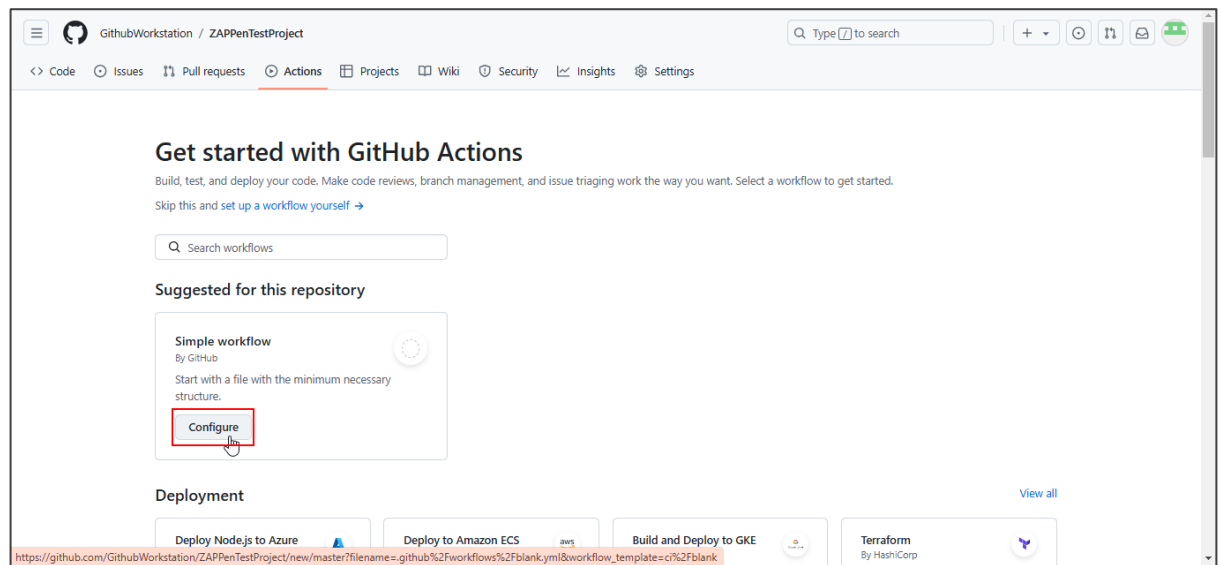
The repository is created successfully as shown below:



1.3 Click on the **Actions** tab



1.4 Click on **Configure** in the **Simple workflow** section



1.5 Add the following code to the **.yaml** file as shown below:

name: OWASP ZAP Scan

on:

pull_request:

branches:

- main # Trigger ZAP scan on PRs targeting the `main` branch

push:

branches:

- main # Or trigger on push to the `main` branch

workflow_dispatch: # Allow manual triggering of the workflow

permissions:

issues: write

jobs:

zap_scan:

runs-on: ubuntu-latest

steps:

Checkout the repository

- **name:** Checkout Repository

uses: actions/checkout@v2

Set up Python (optional, if your application is Python-based)

- **name:** Set up Python

uses: actions/setup-python@v2

with:

python-version: '3.8'

Run ZAP Scan

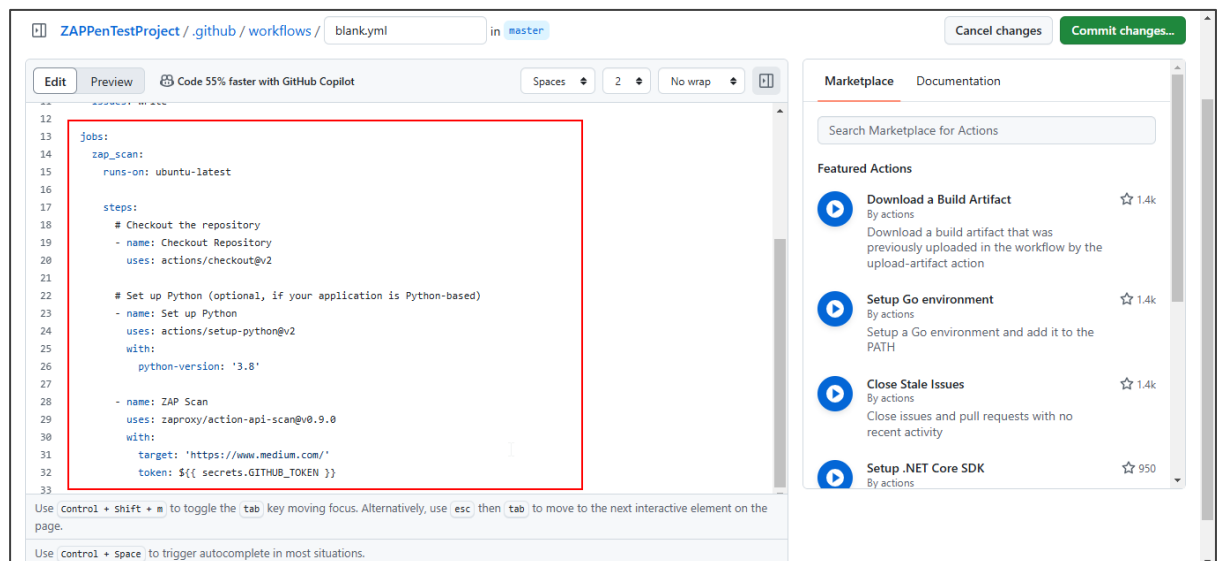
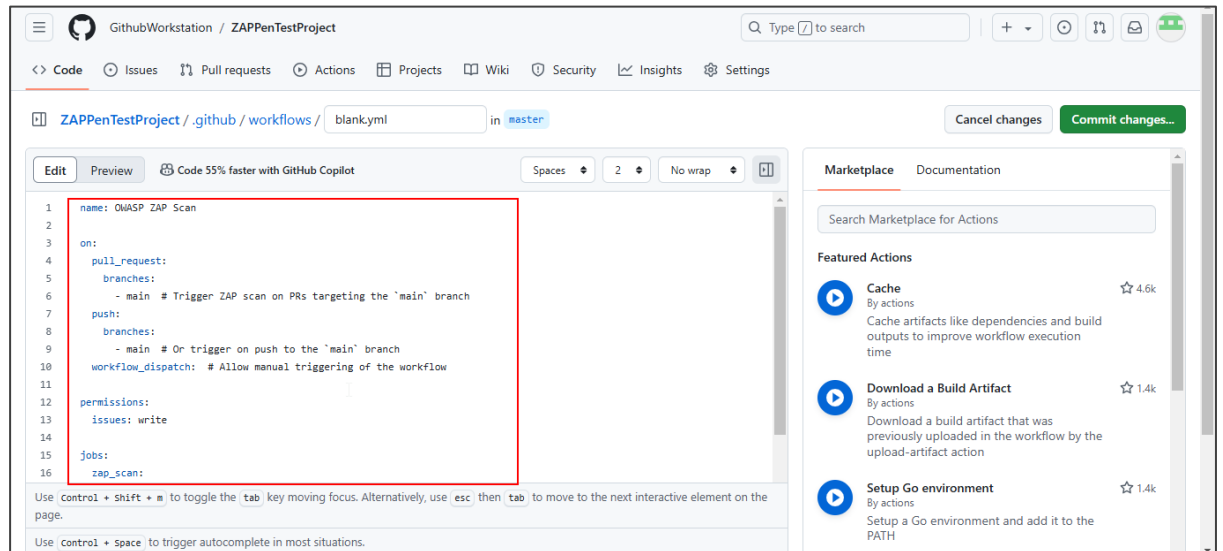
- name: ZAP Scan

uses: zapproxy/action-api-scan@v0.9.0

with:

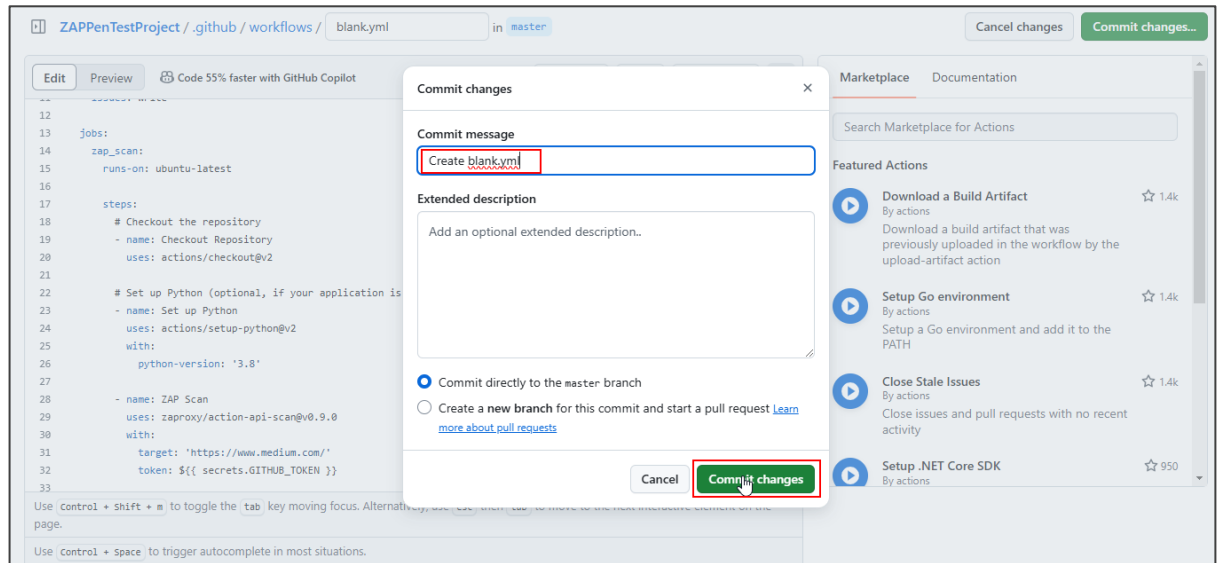
target: 'https://www.medium.com/'

token: \${ secrets.GITHUB_TOKEN }

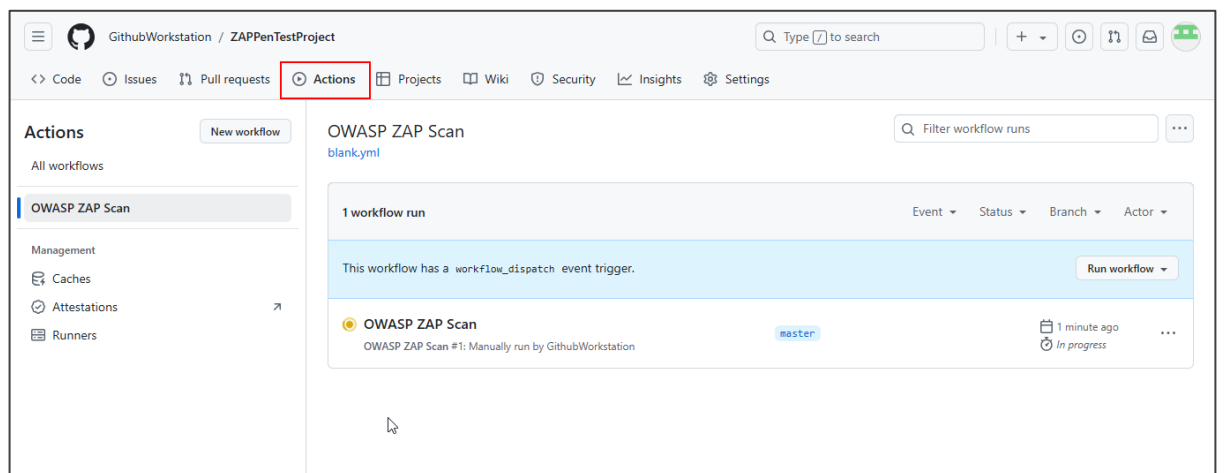


Note: The ZAP API Scan Python script spiders the target URL and performs a full scan against an API defined by SOAP using ZAP.

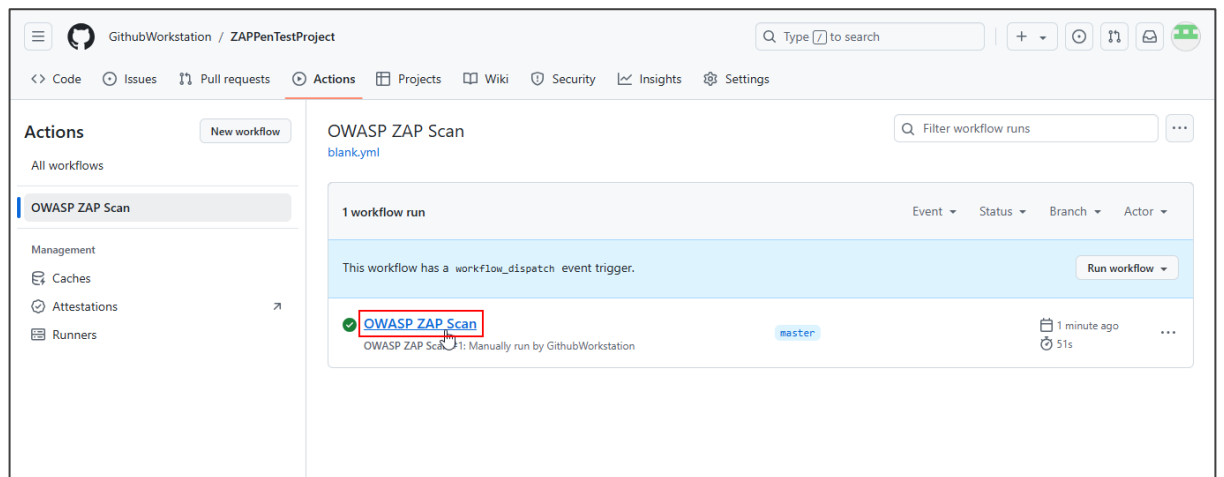
1.6 Click on the **Commit changes...** button, add a commit message, and then click **Commit changes**



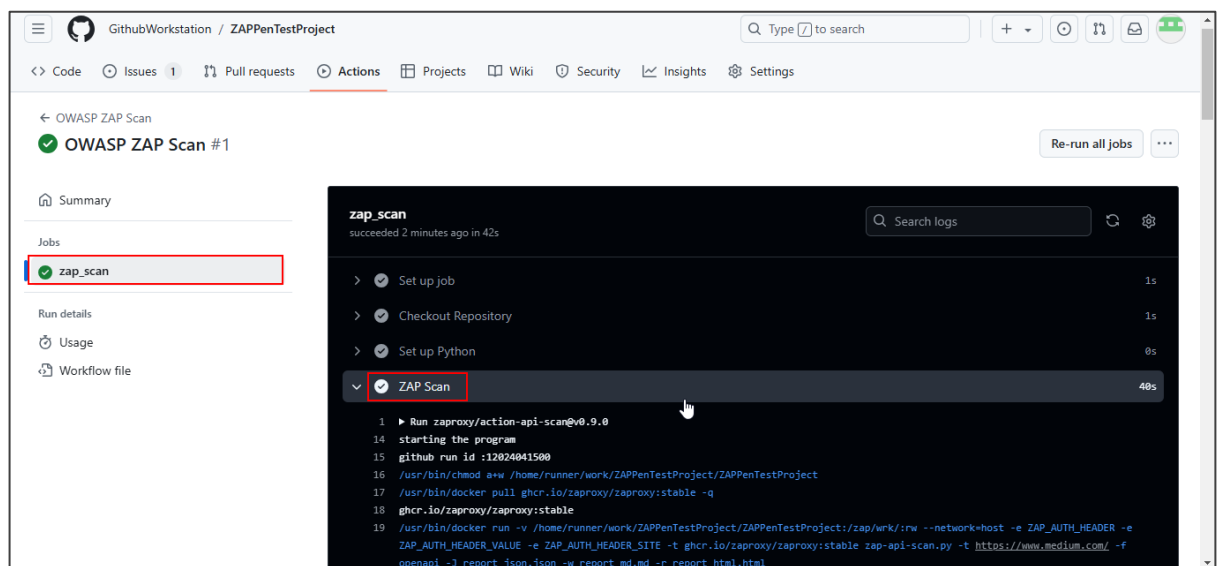
1.7 Navigate to the **Actions** tab to view the workflow



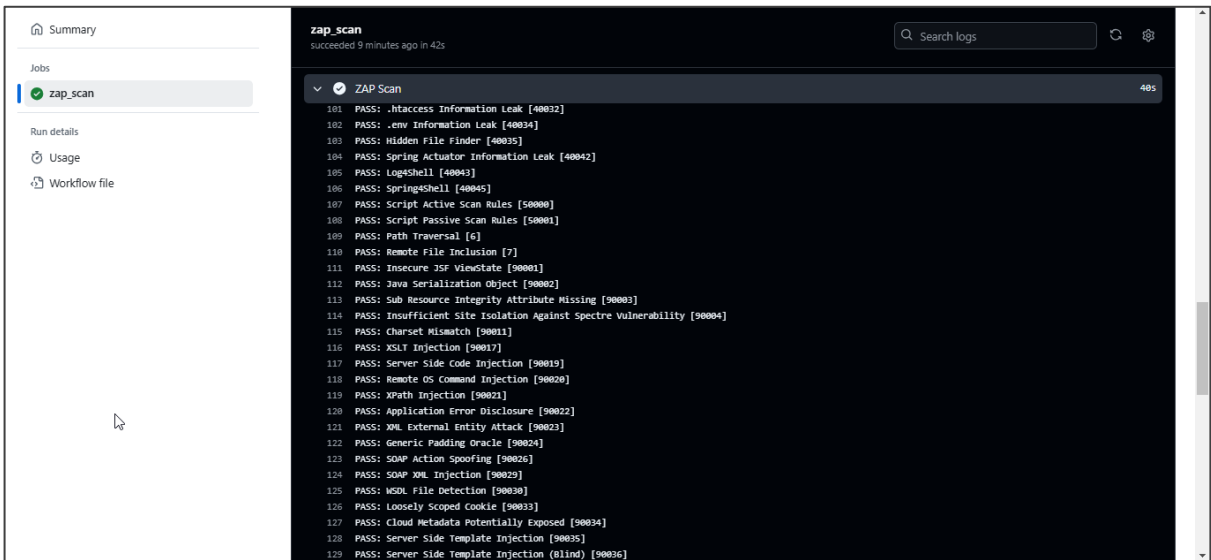
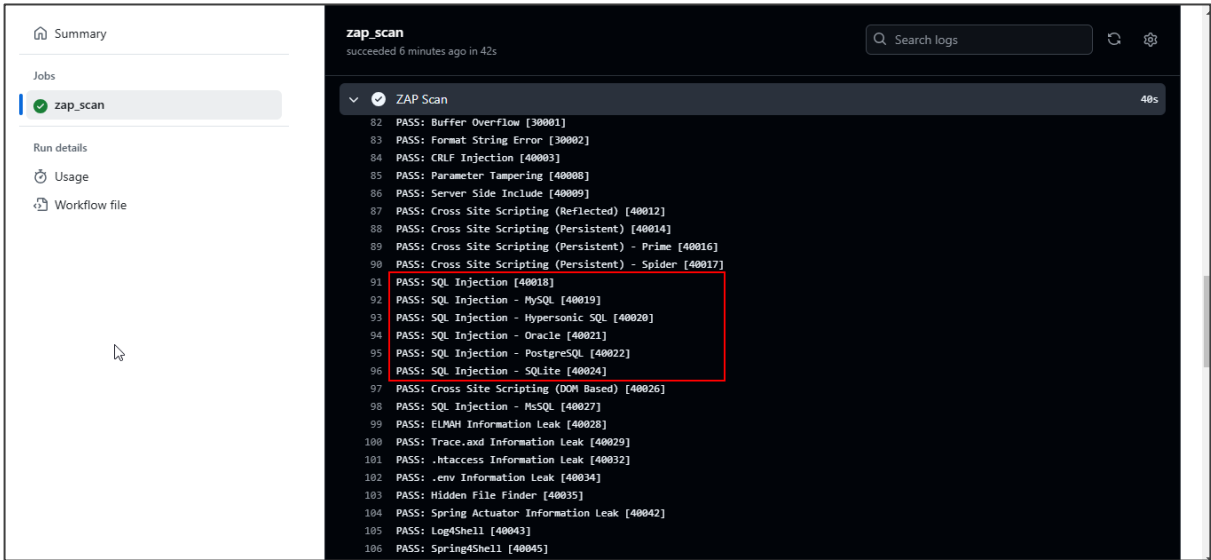
1.8 Click on **OWASP ZAP Scan** as shown below:



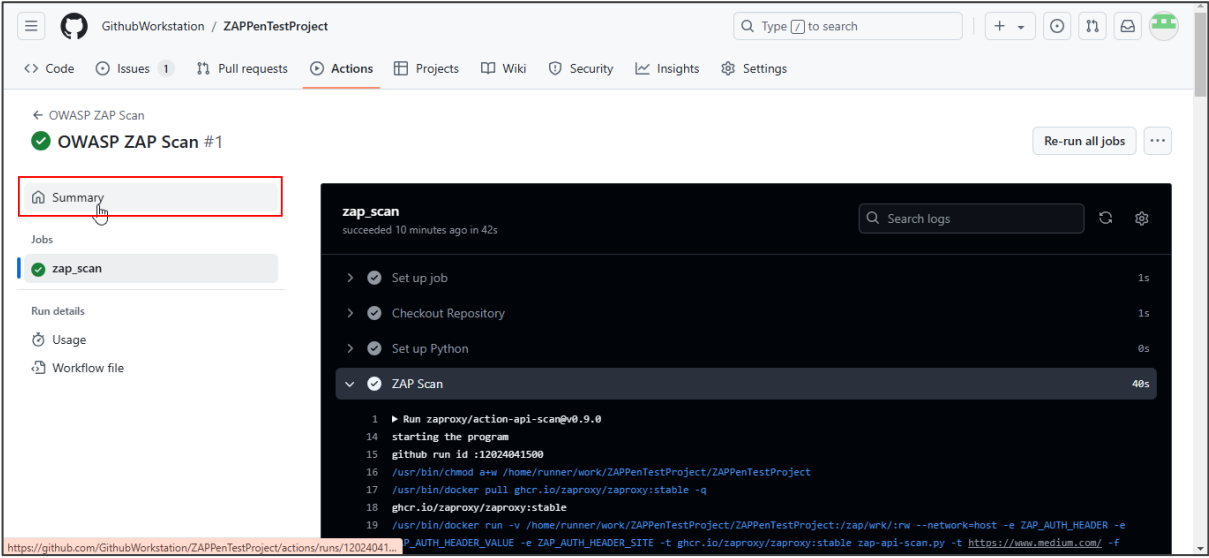
1.9 Navigate to **zap_scan** in the **Jobs** section and view the detailed steps as shown below:



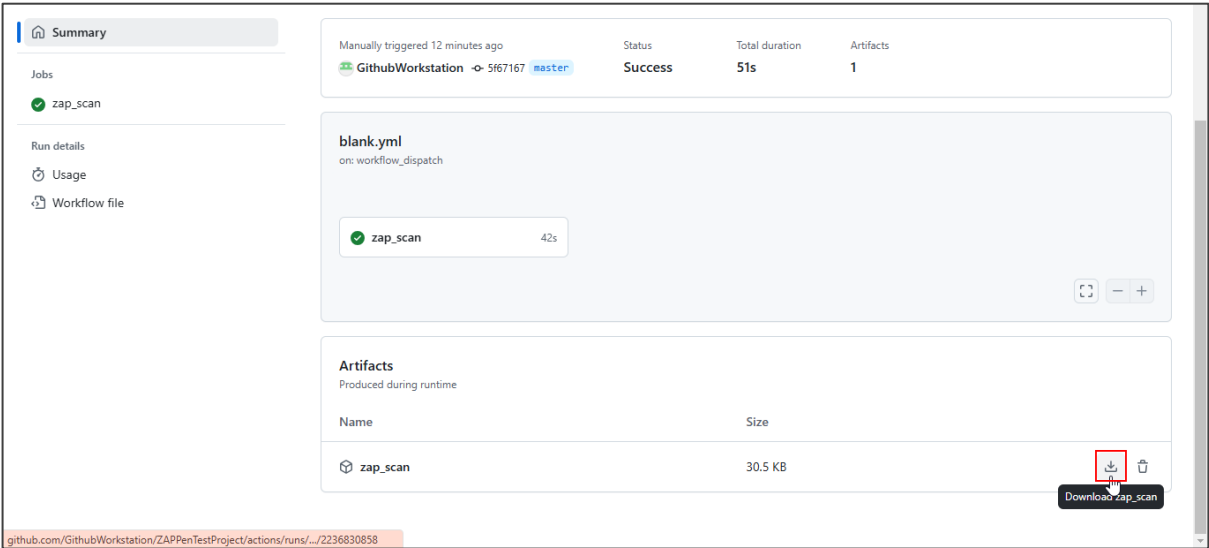
The logs shown in the screenshot below indicate that SQL Injection and other security checks have been performed to assess the security of the provided website URL:



1.10 Click on **Summary**



1.11 Click on the download icon in the **Artifacts** section



1.12 Open the downloaded **report_html.html** file to view the Zap report

← → ↻ File /AppData/Local/Temp/1f991586-7ab4-4e96-8064-693dbb86cb9d_zap_scan%20(1).zip_zap_scan%20(1).zip/report_html... ☆ ⌵ ⌵ ⌵ Relaunch to update



ZAP Scanning Report

Sites: <https://www.medium.com> <https://medium.com>

Generated on Tue, 26 Nov 2024 04:51:28

ZAP Version: 2.15.0

ZAP by [Checkmarx](#)

Summary of Alerts

Risk Level	Number of Alerts
High	0
Medium	4
Low	4
Informational	6
False Positives	0

Alerts

Name	Risk Level	Number of Instances
CSP: Wildcard Directive	Medium	2
CSP: script-src unsafe-inline	Medium	2
CSP: style-src unsafe-inline	Medium	2

Alerts

Name	Risk Level	Number of Instances
CSP: Wildcard Directive	Medium	2
CSP: script-src unsafe-inline	Medium	2
CSP: style-src unsafe-inline	Medium	2
Sub Resource Integrity Attribute Missing	Medium	15
Cookie with SameSite Attribute None	Low	4
Cross-Domain JavaScript Source File Inclusion	Low	12
Permissions Policy Header Not Set	Low	2
Unexpected Content-Type was returned	Low	8
A Client Error response code was returned by the server	Informational	3
Information Disclosure - Suspicious Comments	Informational	4
Loosely Scoped Cookie	Informational	1
Non-Storable Content	Informational	2
Retrieved from Cache	Informational	2
Session Management Response Identified	Informational	2

Alert Detail

Medium	CSP: Wildcard Directive
Description	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks. Including (but not limited to) Cross Site Scripting (XSS), and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
URL	https://medium.com/
Method	GET

By following these steps, you have successfully configured and executed penetration testing on a web application using OWASP ZAP integrated with GitHub Actions to identify vulnerabilities and enhance application security.